

במפגש השביעי של הקורס, המרצה מיכאל התמקד בעולמות של **מודיעין סייבר**, תוך סקירת פורמטים, כלים וקונבנציות המאפשרים לאנשי אבטחת מידע למפות איומים ולהגן על הארגון בצורה פרואקטיבית 1. להלן סיכום הנושאים המרכזיים מהשיעור:

1. מודל MITRE ATT&CK

- זהו ארגון ללא כוונת רווח שיצר מעין "ויקיפדיה אינטראקטיבית" לעולם הסייבר 1, 2.
- **פירוש השם:** Adversarial Tactics, Techniques, and Common Knowledge (טקטיקות, טכניקות וידע משותף של יריבים) 1.
 - **מטרה:** יצירת **שפה אחידה וסטנדרטיזציה** בעולם הסייבר, המאפשרת לארגונים שונים לשתף מידע על פריצות בצורה הומוגנית 2, 3.
 - **מבנה:** המודל בנוי כמטריצה רחבה המפרטת טכניקות ושיטות הגנה לכל תרחיש אפשרי (למשל בעולמות הענן), כאשר לכל פרצה יש מזהה (ID) בינלאומי 2, 3.
 - **אסטרטגיה מול טקטיקה:** המרצה הסביר שמהלך **אסטרטגי** הוא תכנון ארוך טווח, בעוד שמהלך **טקטי** (בו מתמקד המודל) הוא טיפול בנקודה המיידית בזמן 1.

2. שרשרת התקיפה (Cyber Kill Chain - CKC)

המודל מתמקד בפירוק תהליך התקיפה לשלבים כדי לזהות היכן ניתן לשבור את השרשרת ולסכל את התקיפה 1, 4. בעוד שבעבר התייחסו לשלבים כטוריים (אחד אחרי השני), היום מבינים שתוקף יכול **לקפוץ בין שלבים** 5, 6.

שבעת שלבי השרשרת כפי שהוצגו בשיעור:

1. **איסוף מידע (Reconnaissance):** שימוש ב-OSINT (מודיעין ממקורות גלויים כמו רשתות חברתיות) לחיפוש נקודות תורפה 6, 7. זהו השלב שבו הכי זול לבלום תקיפה, אך הכי קשה לזהות אותה 7, 8.
2. **חימוש (Weaponization):** הכנת הכלי התוקף 7.
3. **מסירה/התפשטות (Delivery):** החדרת הווירוס או הקוד לרשת 7.
4. **ניצול/ביצוע המשימה (Exploitation):** חשיפת המערכת למלור או סוס טרויאני 5.
5. **התקנה (Installation):** פתיחת **Backdoor** (דלת אחורית) והשתלטות על אזורים 5.
6. **פיקוד ובקרה (C2):** יצירת ערוץ דו-כיווני המאפשר לתוקף לשלוט במערכת מבחוץ 5, 9.
7. **פעולה ביעד (Actions on Objectives):** השלב הסופי - שליפת מידע, הצפנה (Ransomware) או השחתה 5, 10.

3. טכניקות וכלים בולטים

- **TTPs:** ראשי תיבות של Tactics, Techniques, and Procedures (טקטיקות, טכניקות ונהלים) המהווים את בסיס מודל ה-11 ATT&CK.
- **Mimikatz:** כלי קוד פתוח המשמש לגניבת שמות משתמש וסיסמאות מתוך הזיכרון של Windows (תהליך ה-4, LSASS).
- **Cobalt Strike:** פלטפורמה מסחרית שנועדה במקור לסימולציות של "צוותים אדומים" (Red Teams), אך הפכה לכלי פופולרי בקרב האקרים לבניית מתקפות מתוכננות 11.
- **Living off the Land:** טכניקה שבה התוקף משתמש בכלים קיימים בתוך המערכת הארגונית כדי להחביא את עצמו ולבנות בסיס תקיפה מבלי להכניס קבצים חשודים מבחוץ 12.
- **העלאת הרשאות (Privilege Escalation):** ניסיון של התוקף להפוך ליזרזר חזק יותר (אדמין) כדי לקבל גישה לאזורים מוגבלים 12.

4. אסטרטגיות הגנה מתקדמות

- **מעבר מהגנה מסורתית לפרואקטיבית:** במקום להיות "חכמים בדיעבד" ולתקן רק אחרי פריצה, ארגונים משתמשים היום ב-AI כדי לזהות אנומליות ואיסוף מודיעין מקדים 13.
- **מלכודות דבש (Honeypot):** סביבה מבודדת המושכת תוקפים כדי ללמוד על דפוסי הפעולה שלהם ("Hunt") מבלי לסכן את הארגון 14. המרצה ציין כי לימוד התנהגות התוקף ב-Honeypot יכול להיות שווה זהב עבור הארגון 14.
- **ניטור התנהגותי:** מערכות הלומדות את הרגלי ההקלדה והשימוש של העובד (בדומה לטכנולוגיות שיווקיות כמו ClickTale) ויודעות לנעול את המחשב אם מזוהה פעולה חריגה (כמו שימוש ב-PowerShell על ידי מזכירה) 15, 16.
- **(DLP (Data Loss Prevention):** מערכות למניעת זליגת מידע, שנועדו לעצור את השלב האחרון בשרשרת התקיפה - הוצאת המידע מהארגון 10, 17.
- **מקרה בוחן (Case Study):** הוזכרה חברת **Movit**, שם התרחשה דליפת מידע אדירה במשך שנים שבה נמשכו ג'יגות של דאטה מבלי שמערכות הניטור יעלו על האנומליה בתעבורת הרשת 18.